

Exploit:

Buffer Overflow, ROP, NX, CFI, Canary

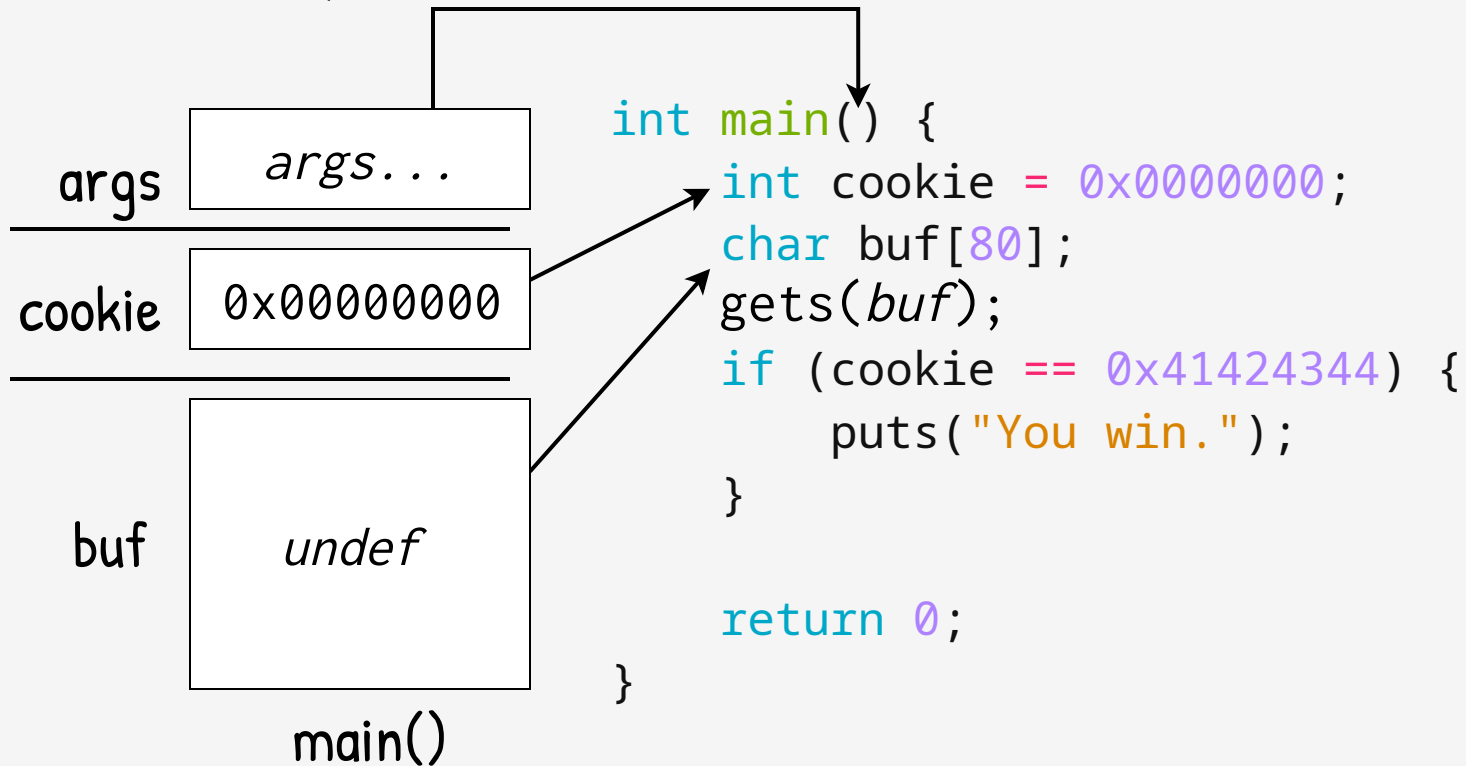
Taller de Seguridad

Ing. Martin Di Paola – Fiuba

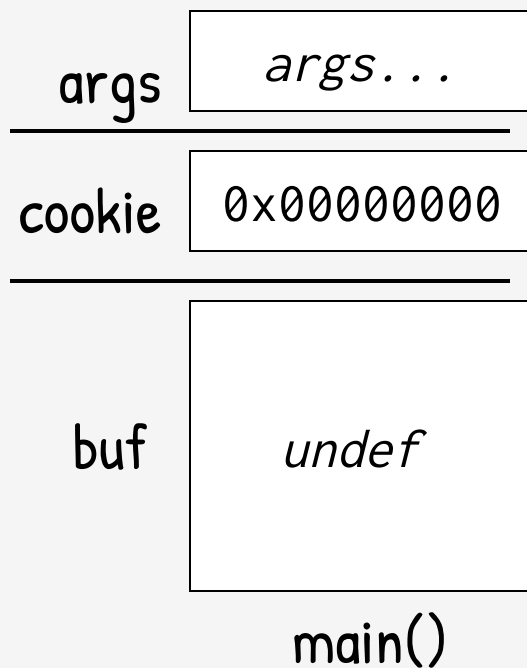
Can you print *"You win"*?

```
int main() {  
    int cookie = 0x00000000;  
    char buf[80];  
    gets(buf);  
    if (cookie == 0x41424344) {  
        puts("You win.");  
    }  
  
    return 0;  
}
```

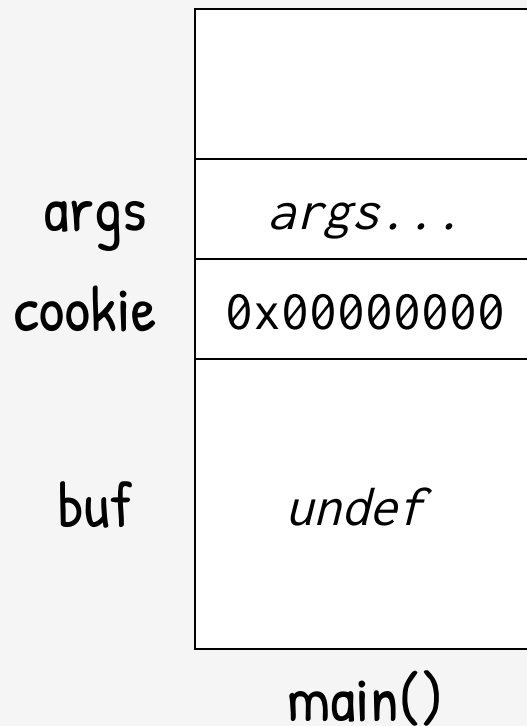
What you see...



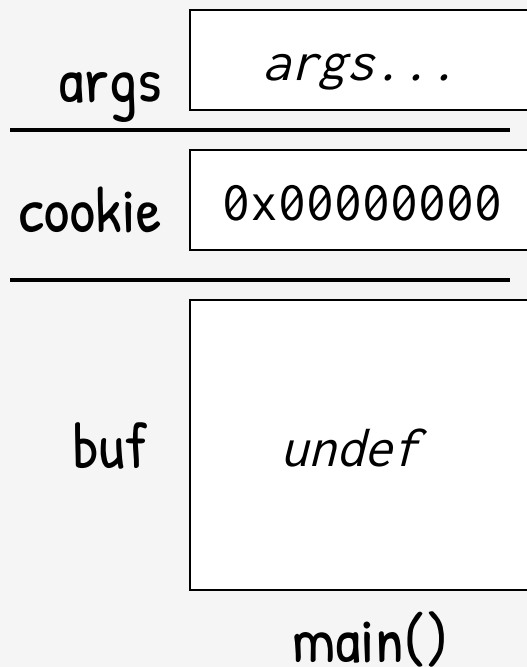
What you see...



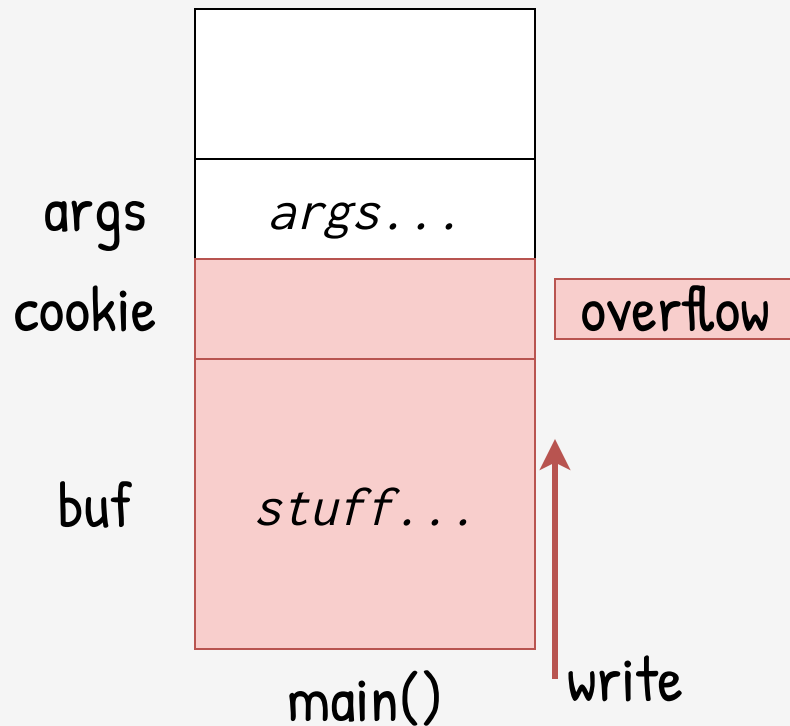
Under the hood...



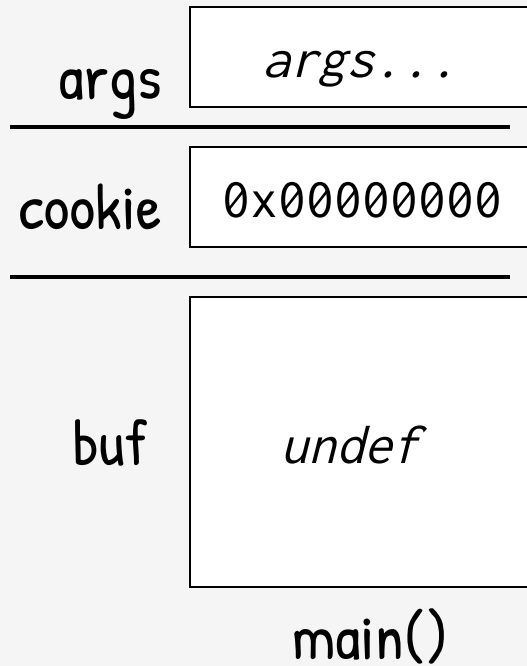
What you see...



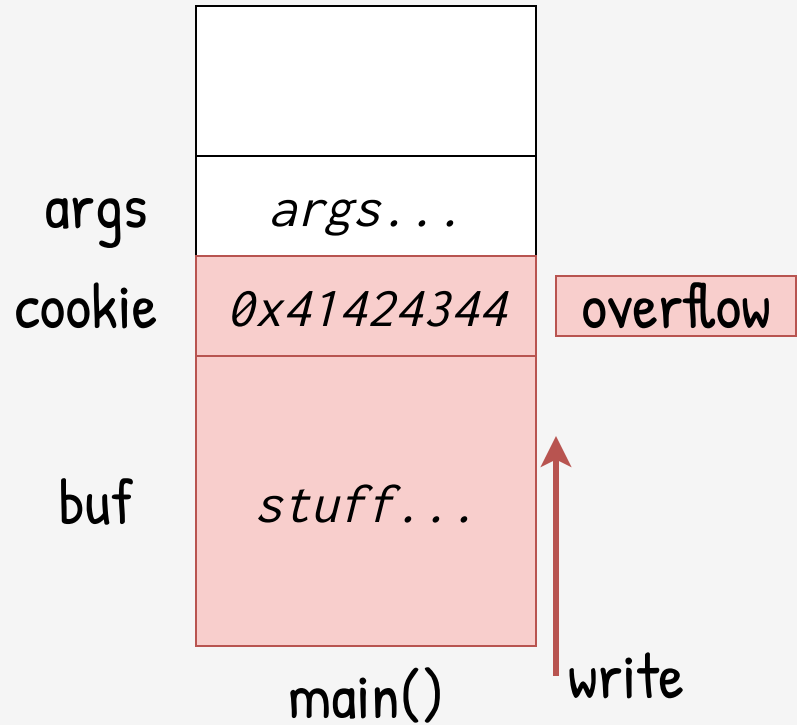
Under the hood...



What you see...



Under the hood...



Can you print *"You win"*?

Can you print
whatever you like?



Can you take control
of the program?



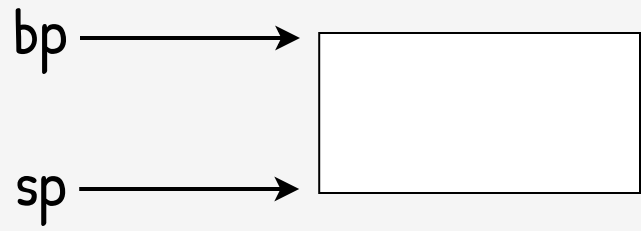
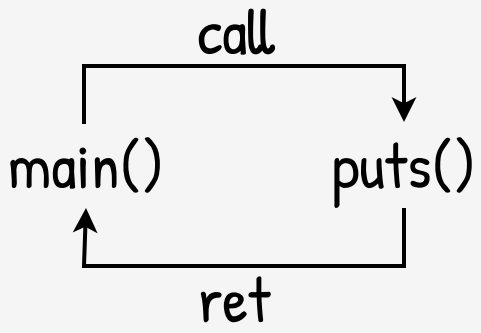
Can you take control
of the host?



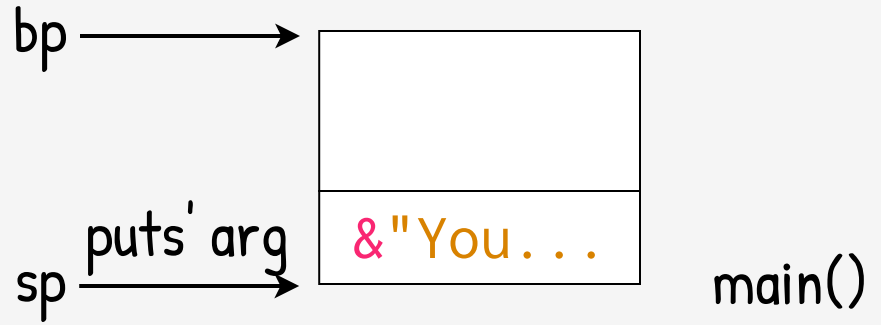
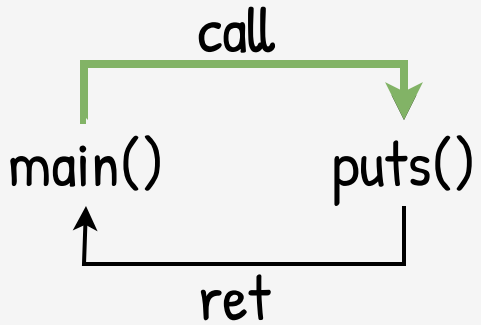
Can you truly win?

```
int main() {  
    int cookie = 0x00000000;  
    char buf[80];  
    gets(buf);  
    if (cookie == 0x41424344) {  
        puts("You win.");  
    }  
  
    return 0;  
}
```

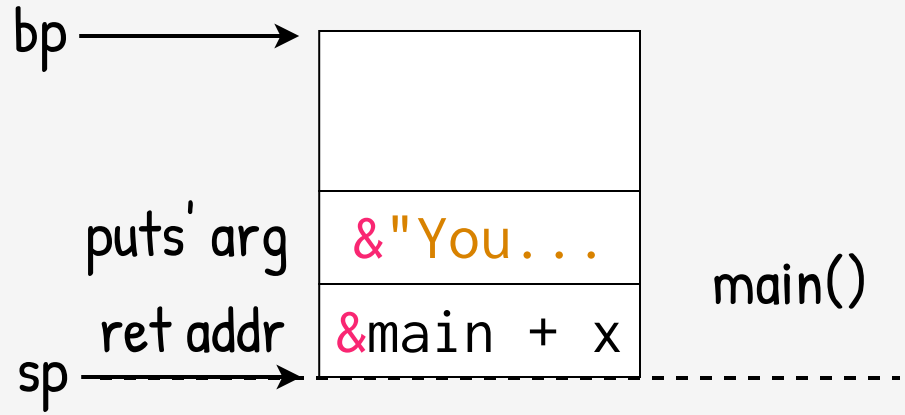
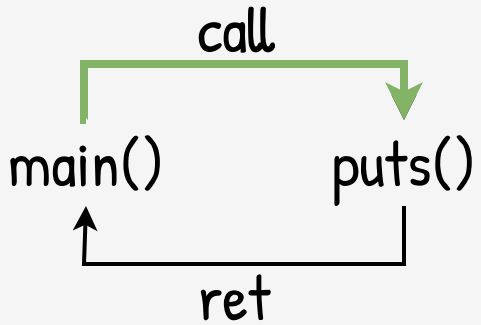
```
int main() {  
    int cookie = 0x00000000;  
    char buf[80];  
    gets(buf);  
    if (cookie == 0x41424344) {  
        puts("Your flag is ~/flag.txt.");  
    }  
  
    return 0;  
}
```

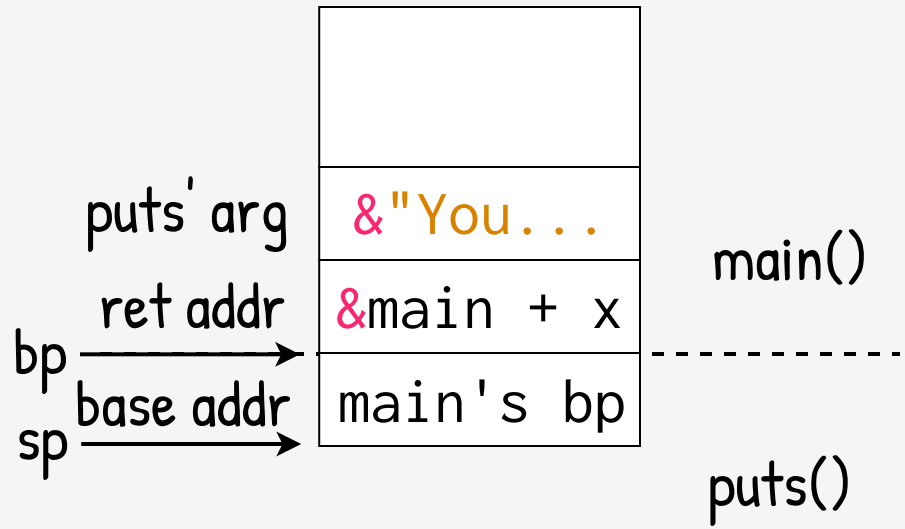
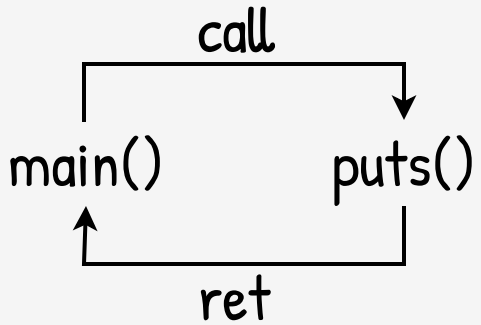
`main()`



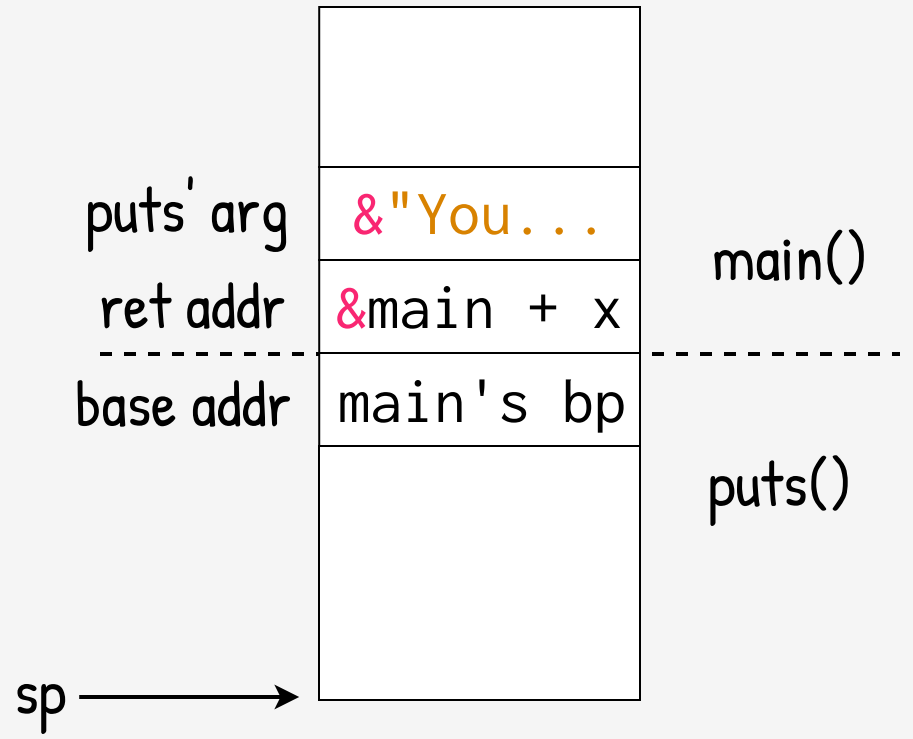
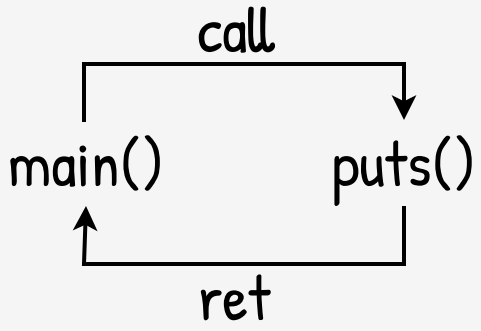
```
{  
  mov ecx &"You..."  
  push ecx  
  call &puts  
}
```

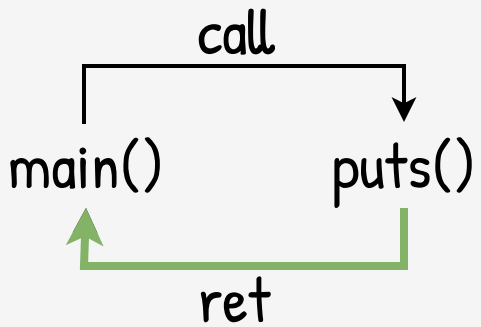


```
mov ecx &"You..."
push ecx
{ call &puts
```

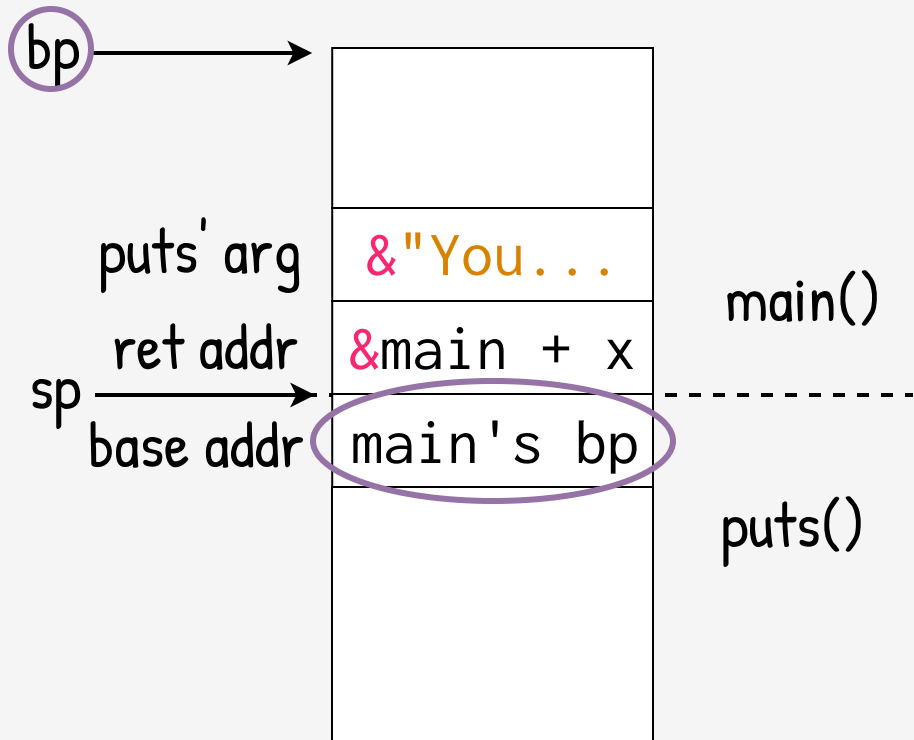


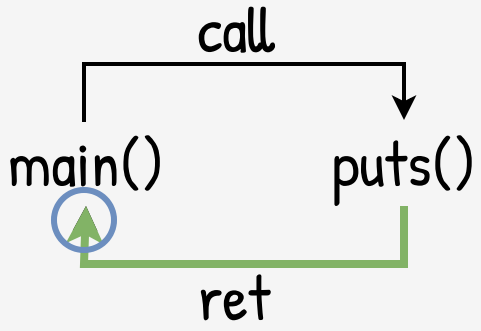
```
push ebp
mov ebp esp
mov ecx esp-8
```



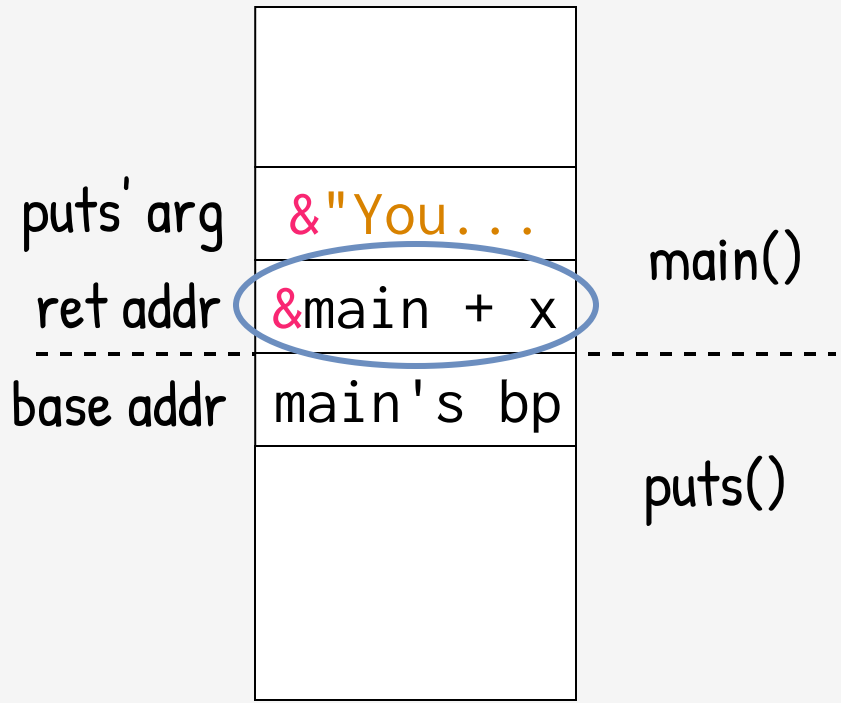


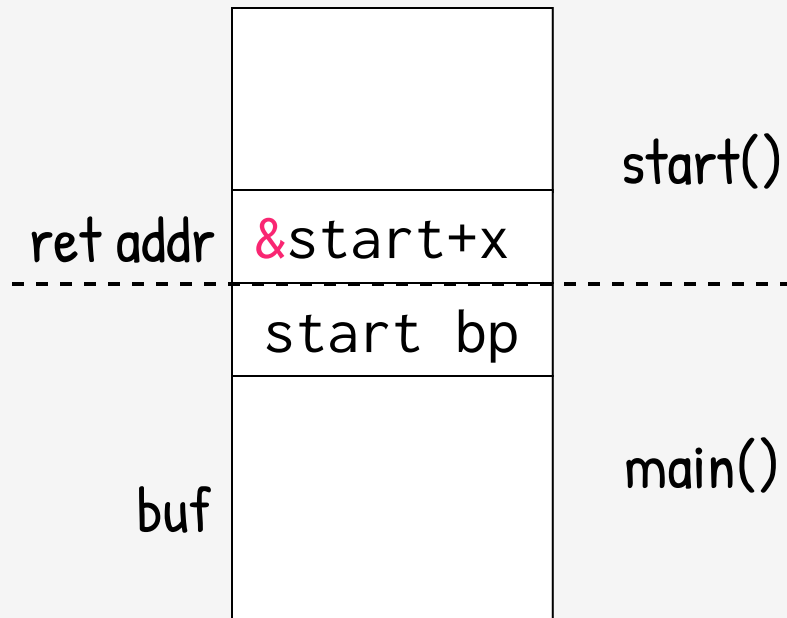
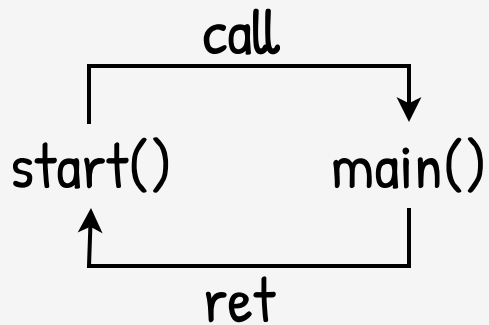
```
{ pop ebp  
  ret
```

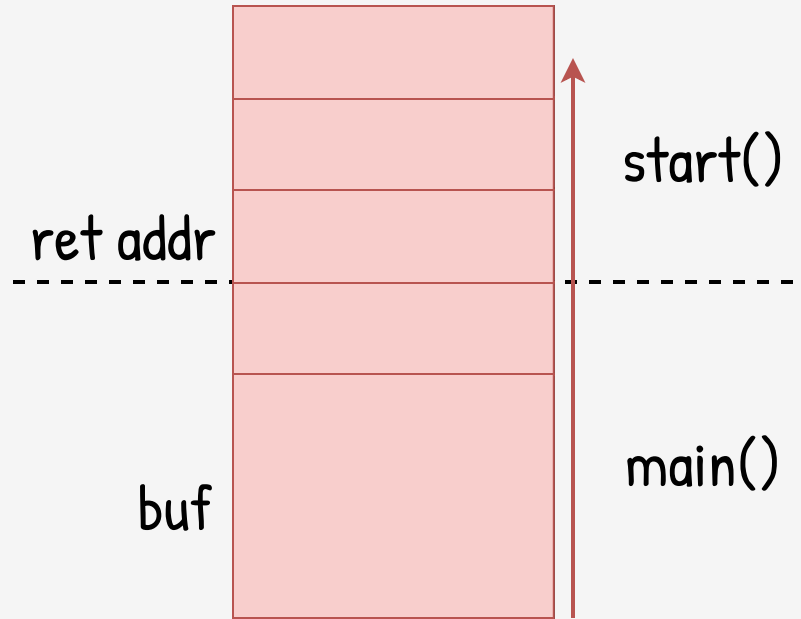
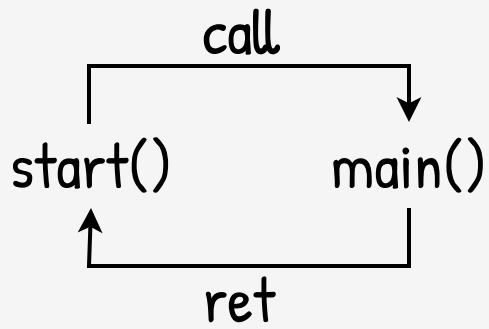


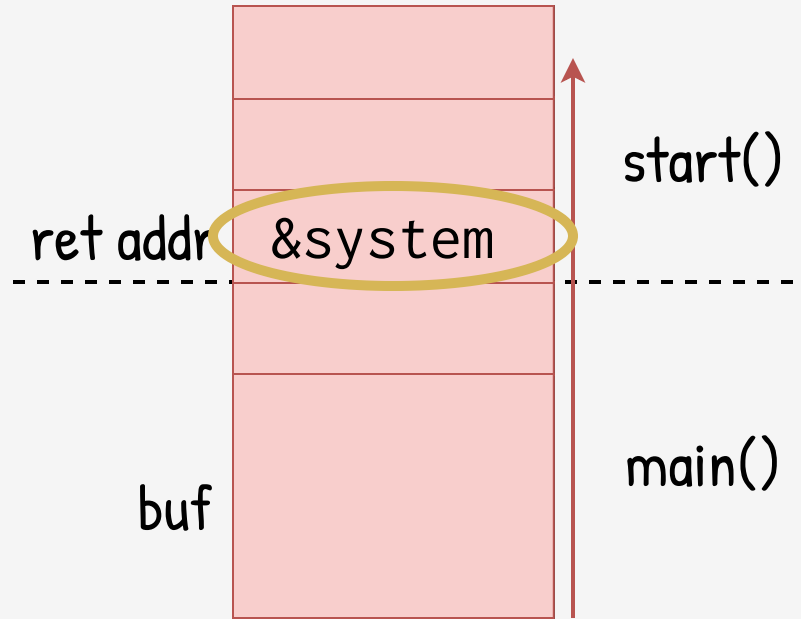
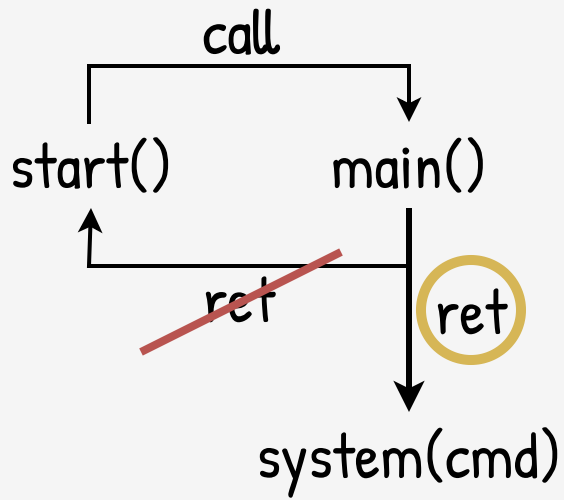


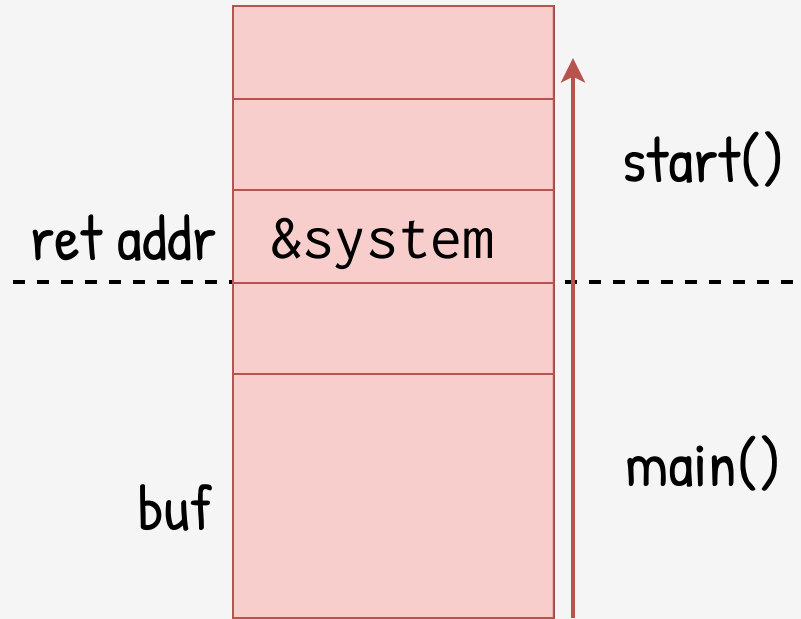
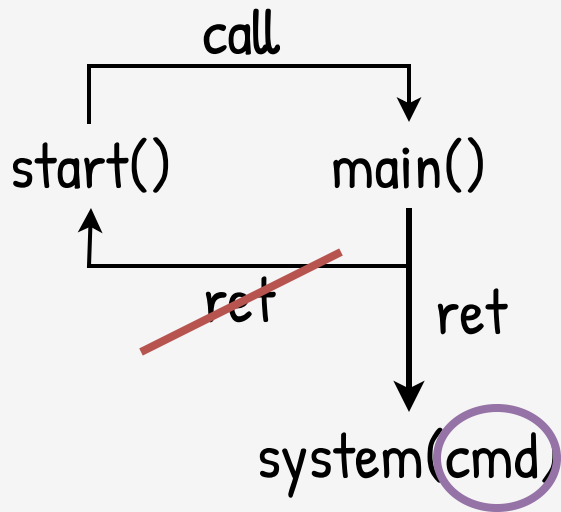
```
pop ebp  
{ ret
```



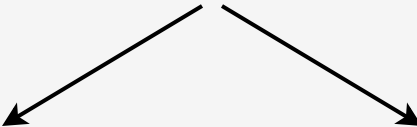








```
puts("Your flag is ~/flag.txt.");
```



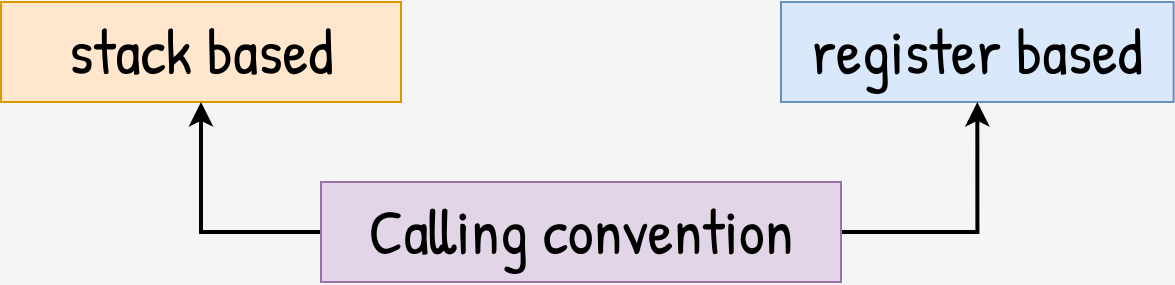
```
mov ecx &"You..."  
push ecx  
call &puts
```

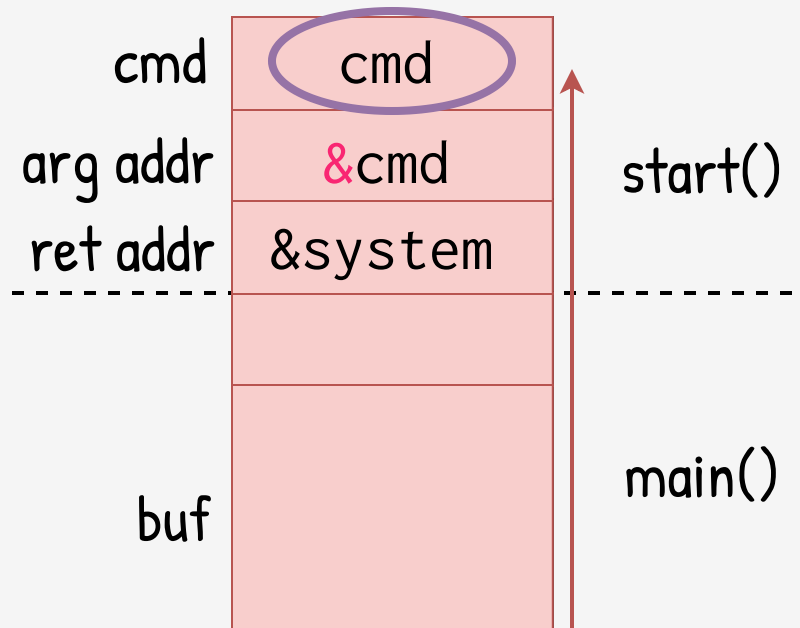
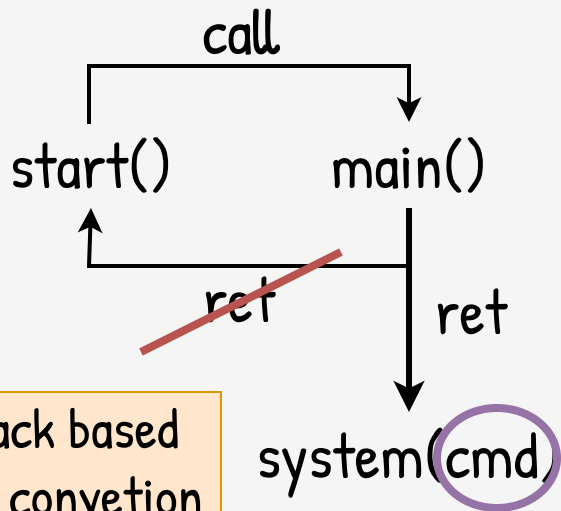
```
mov ecx &"You..."  
call &puts
```

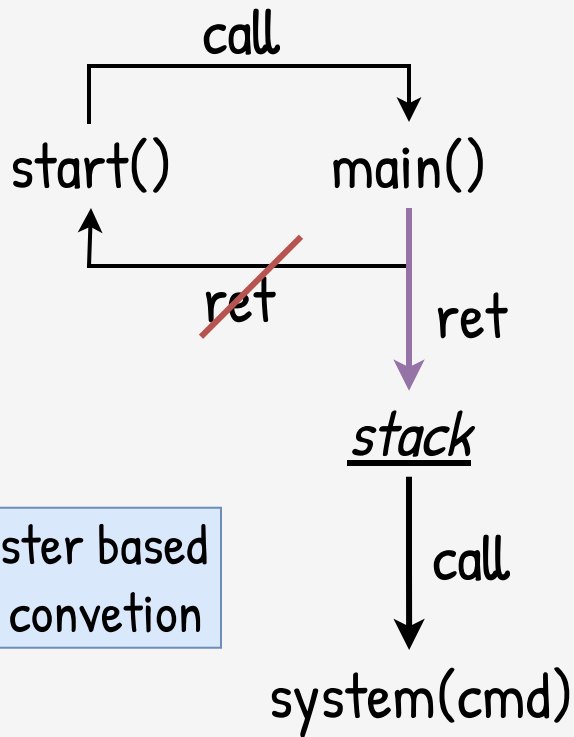
stack based

register based

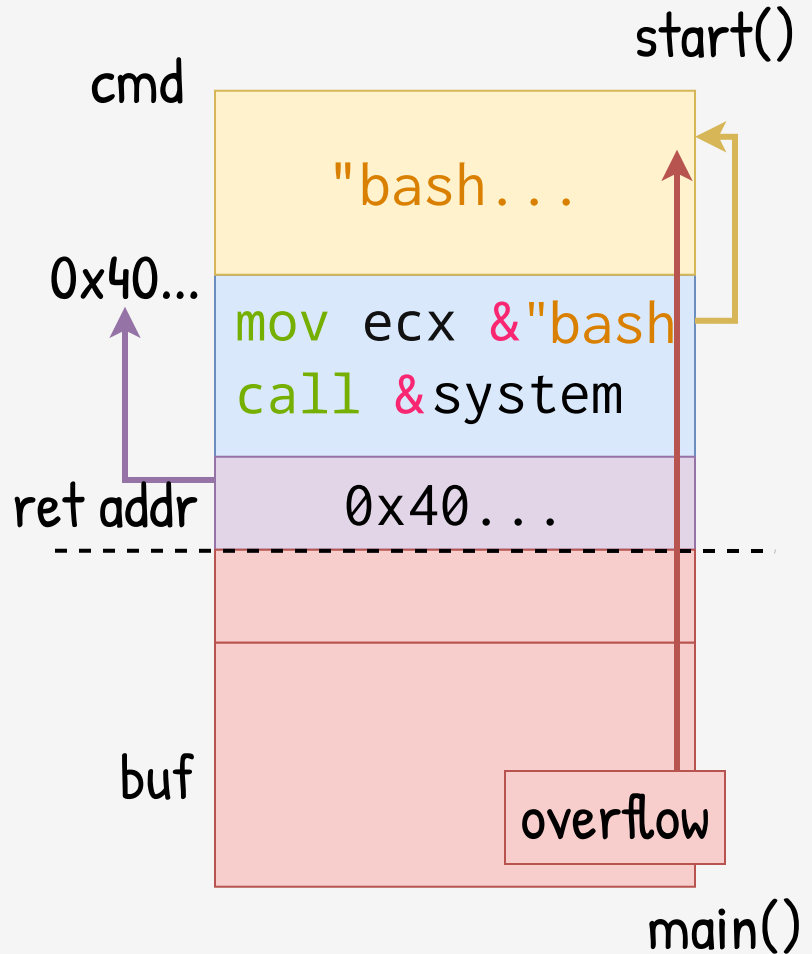
Calling convention

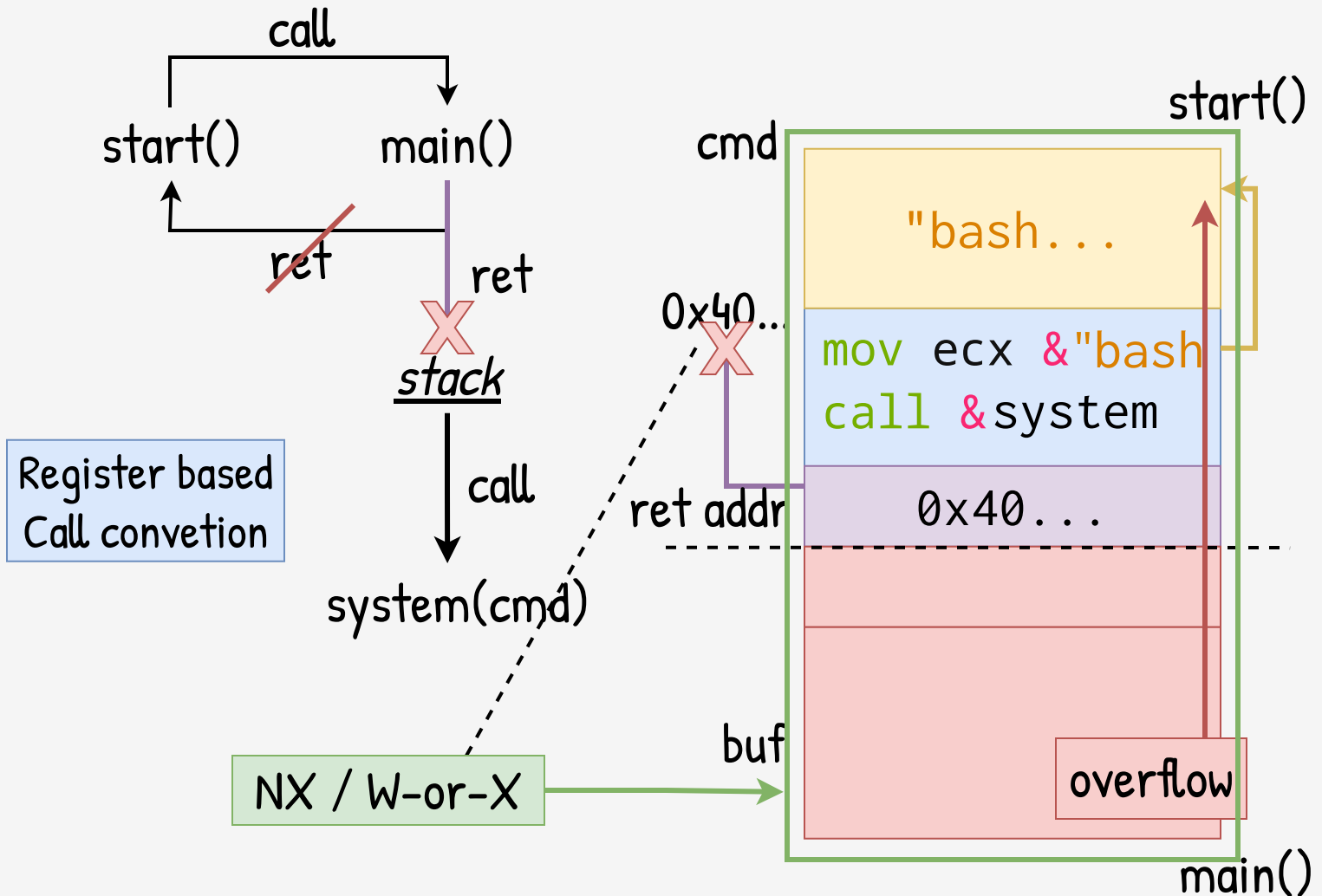


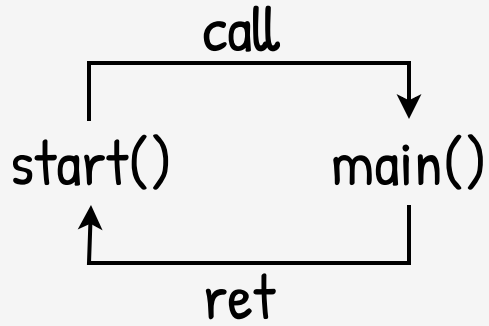




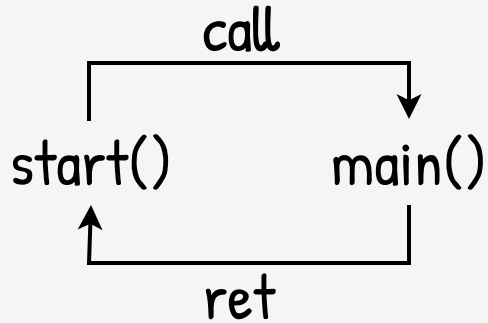
Register based
Call convention





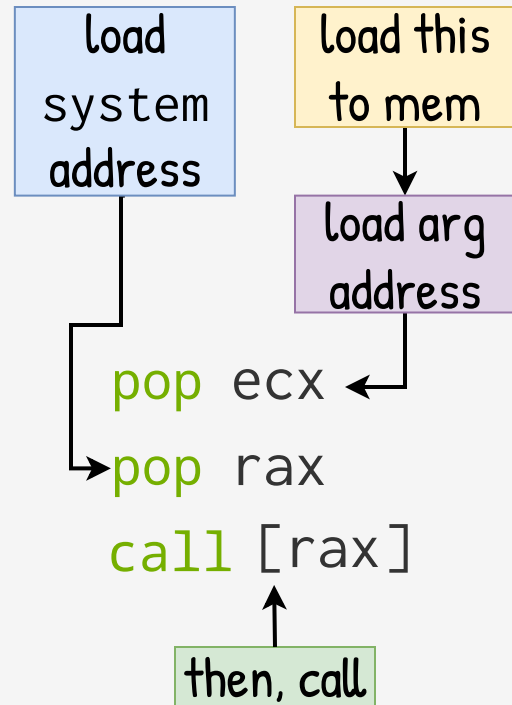


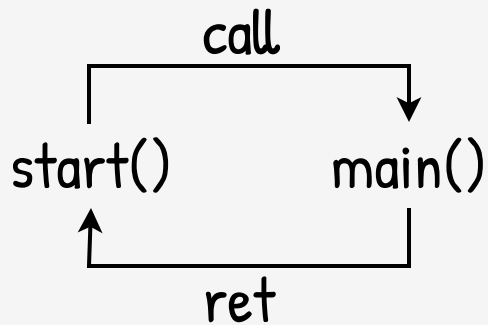
Goal:
call system with
"bash..."



Goal:

call system with
"bash..."

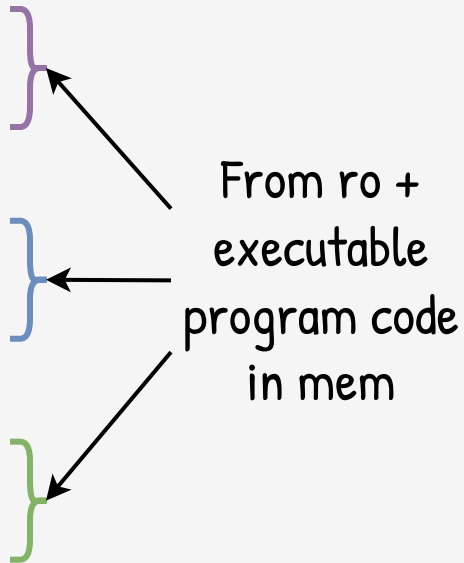




pop ecx
ret

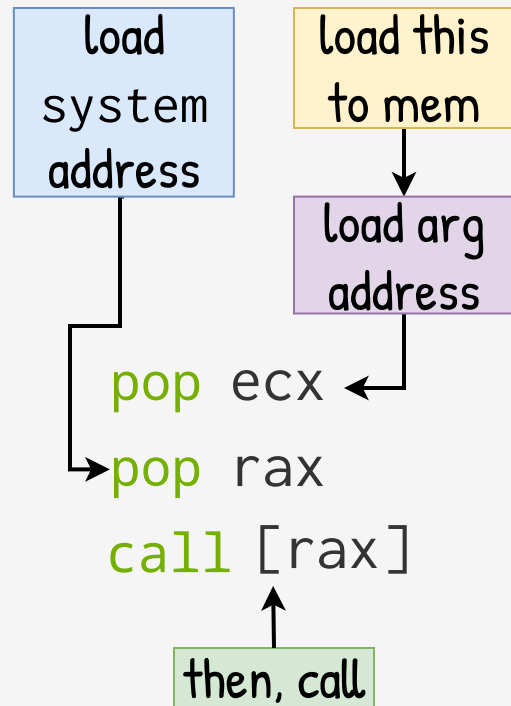
pop rax
ret

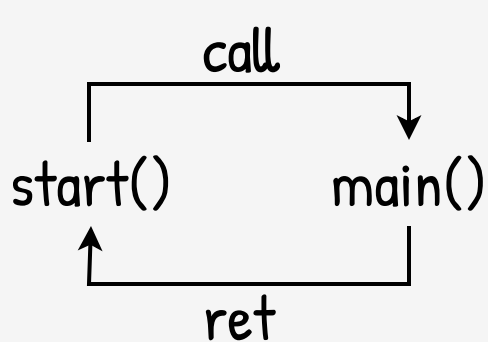
call [rax]



Goal:

call system with
"bash..."

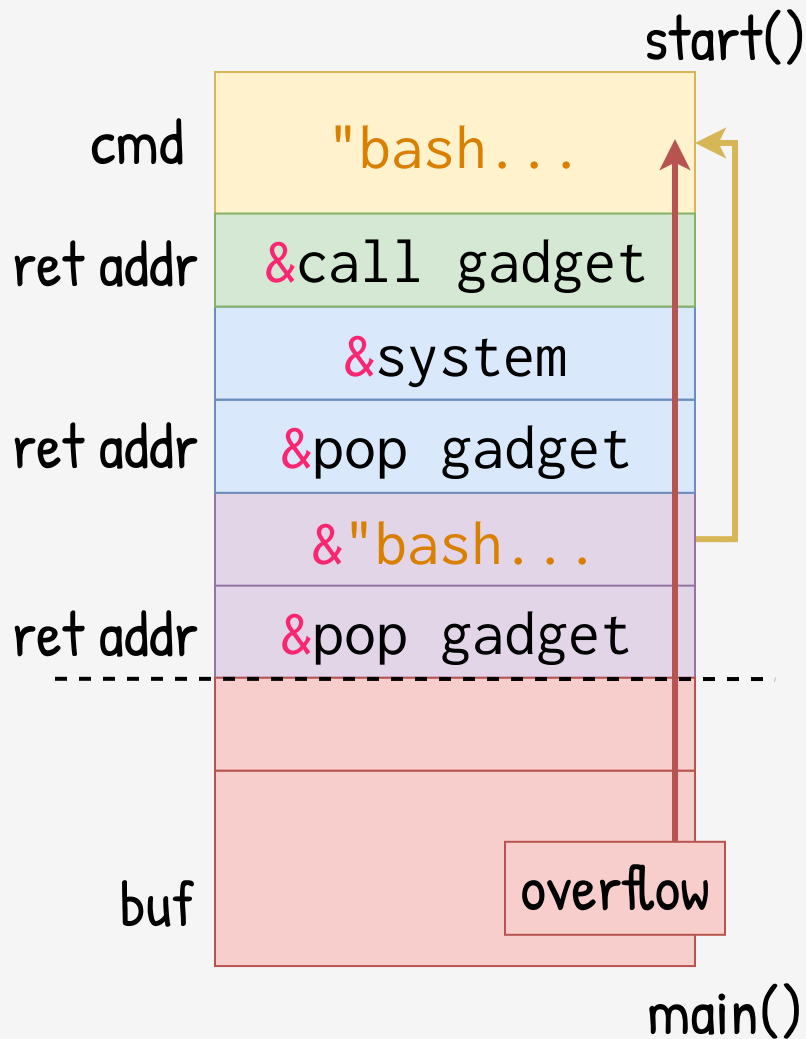


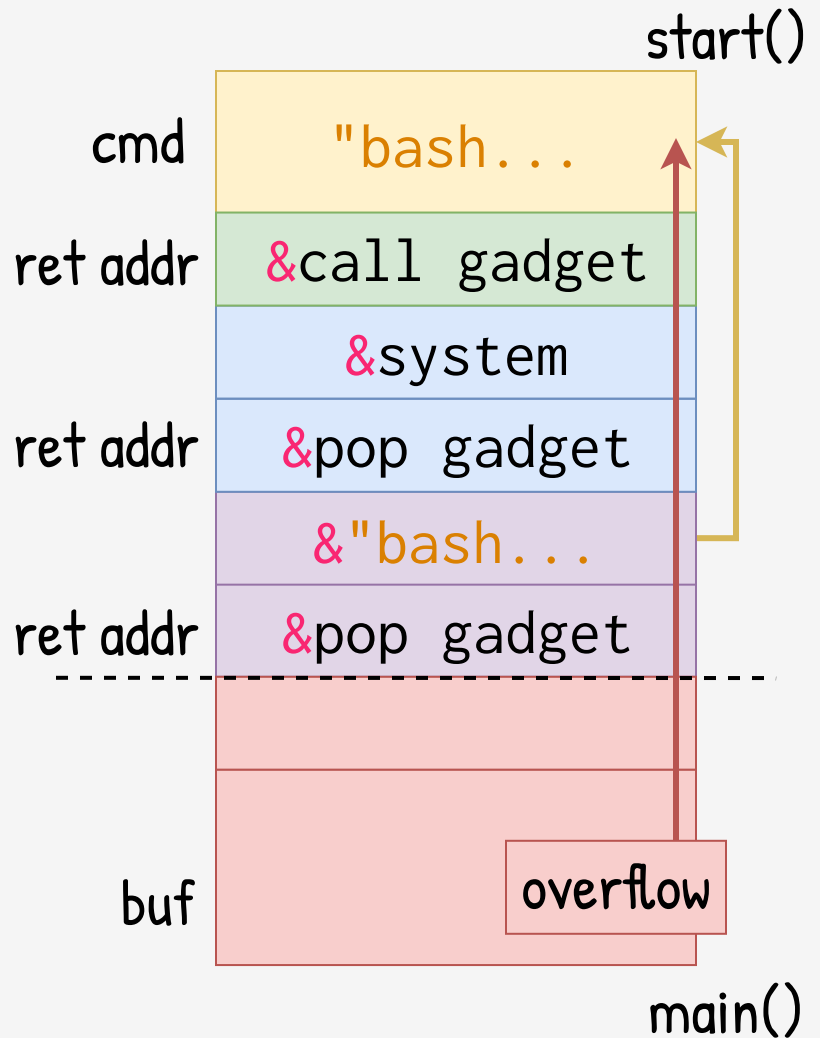
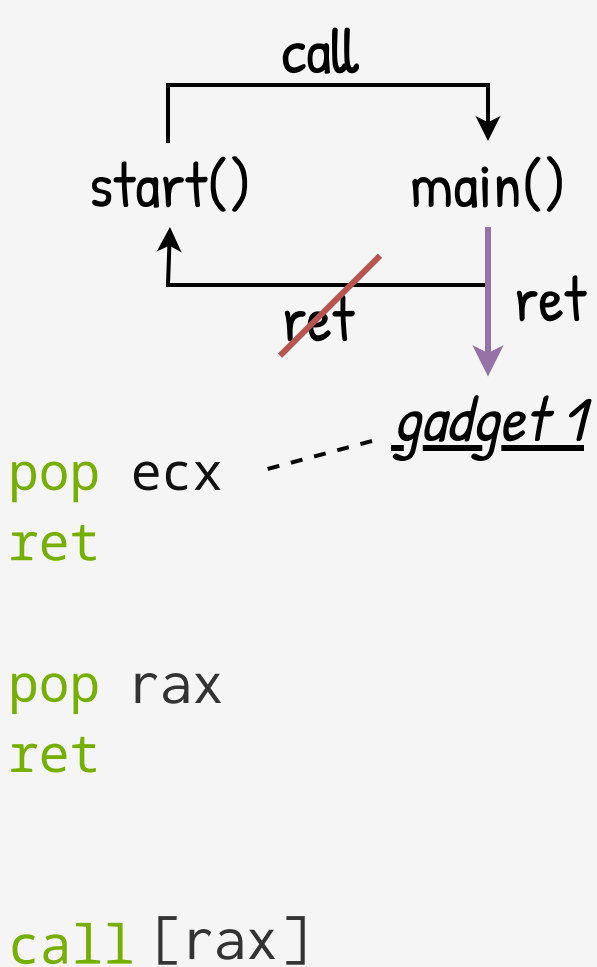


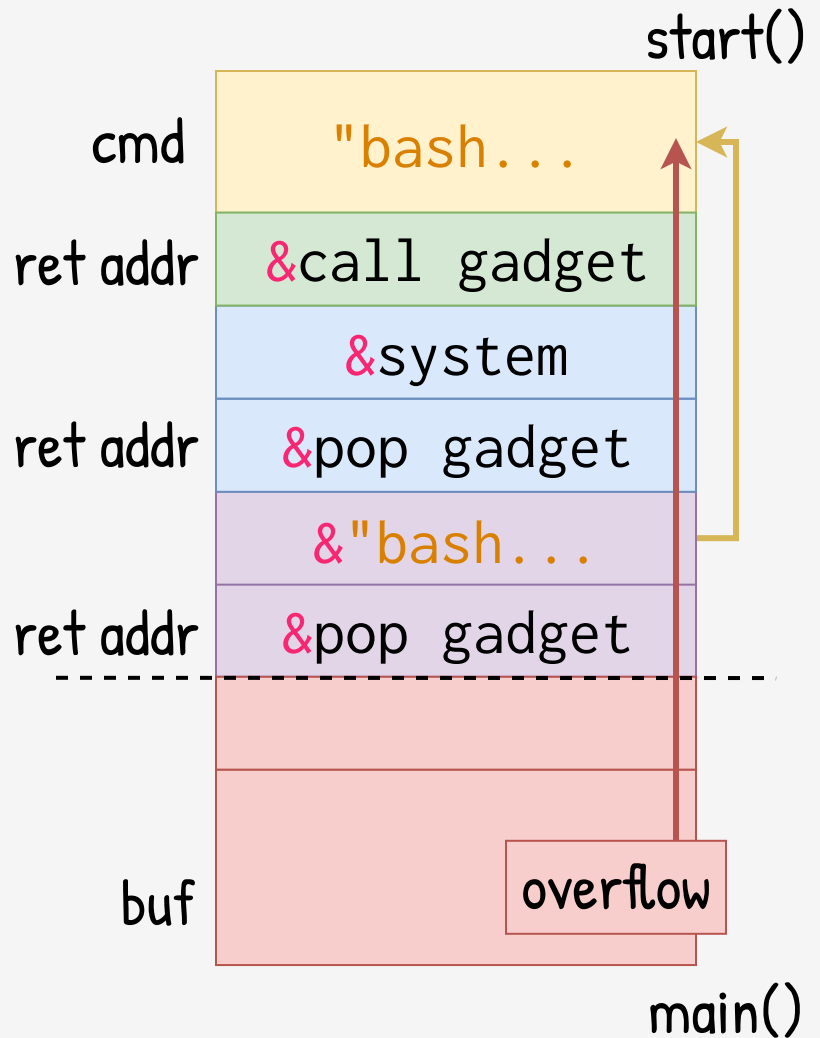
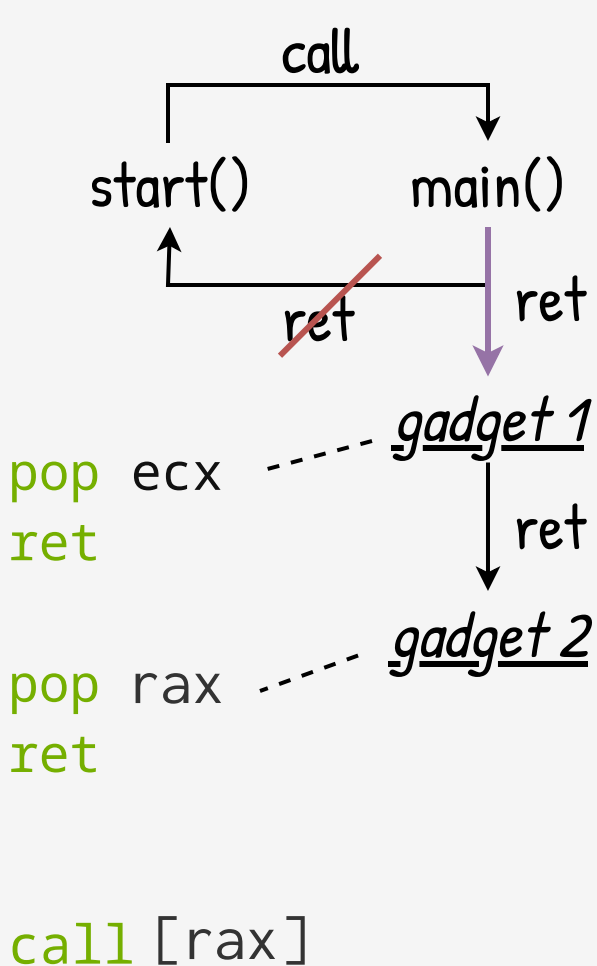
`pop ecx`
`ret`

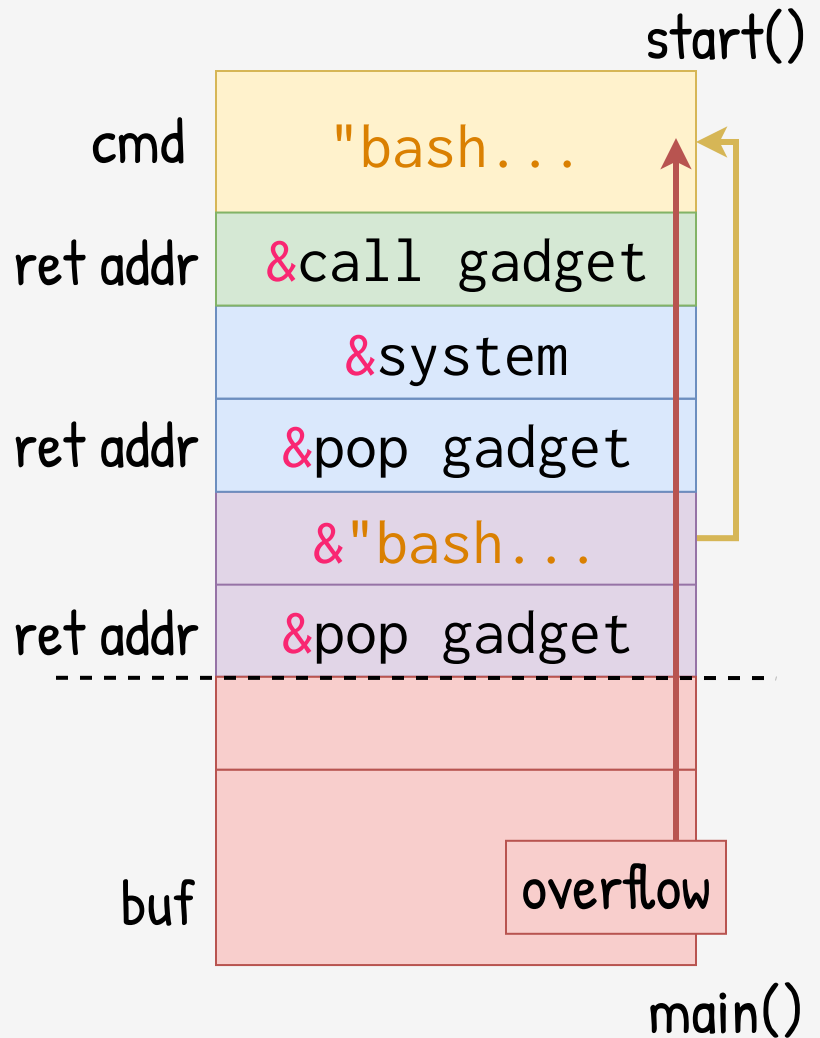
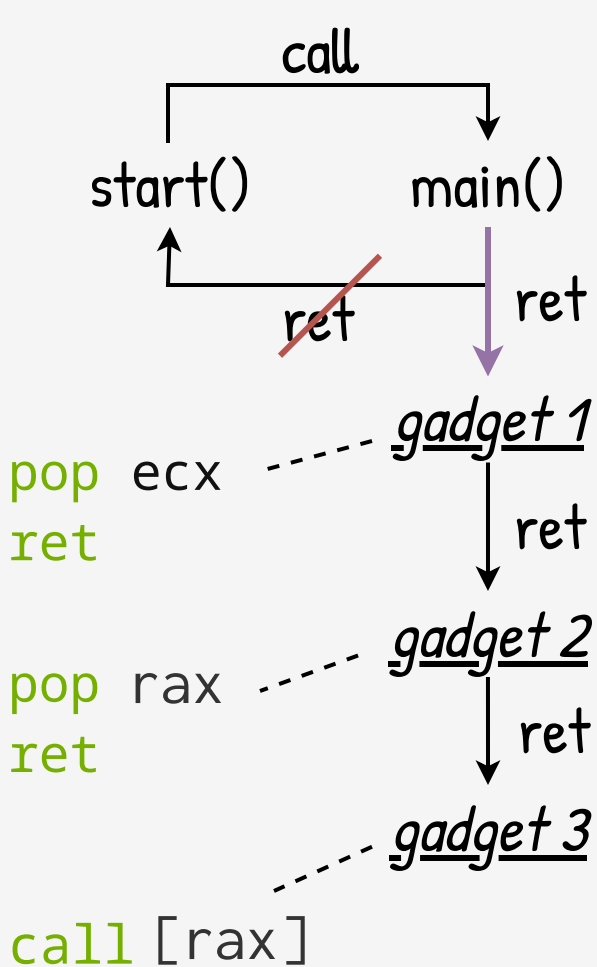
`pop rax`
`ret`

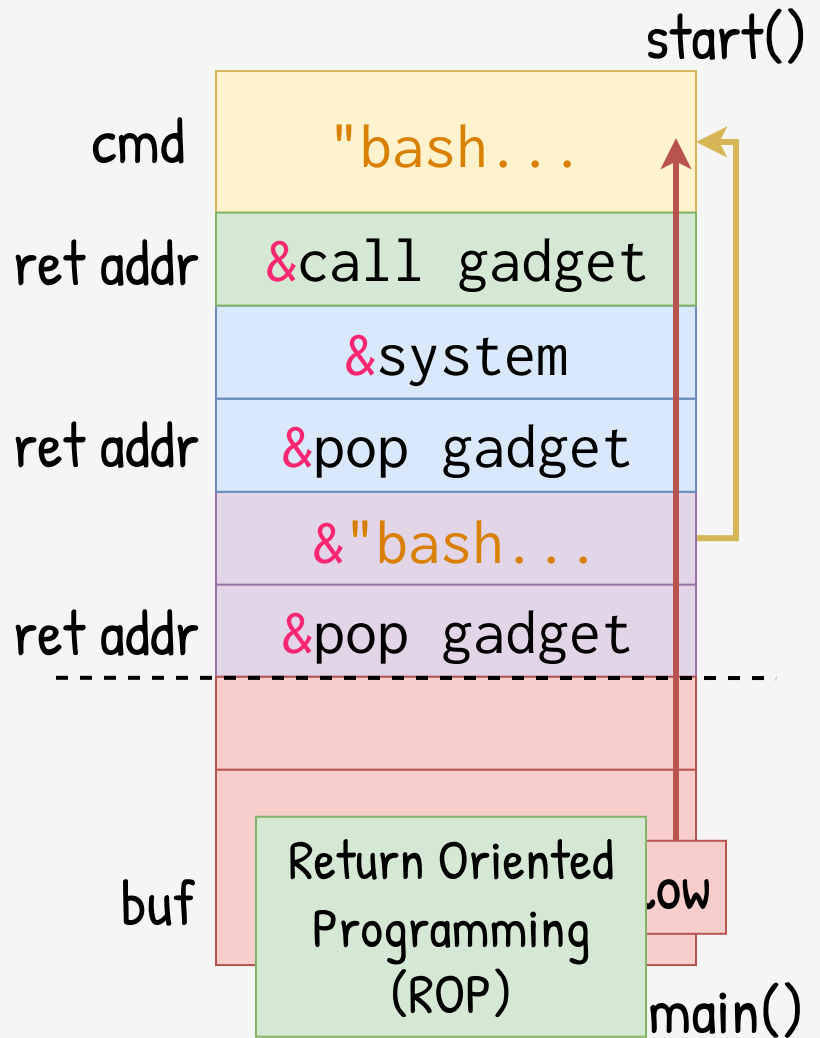
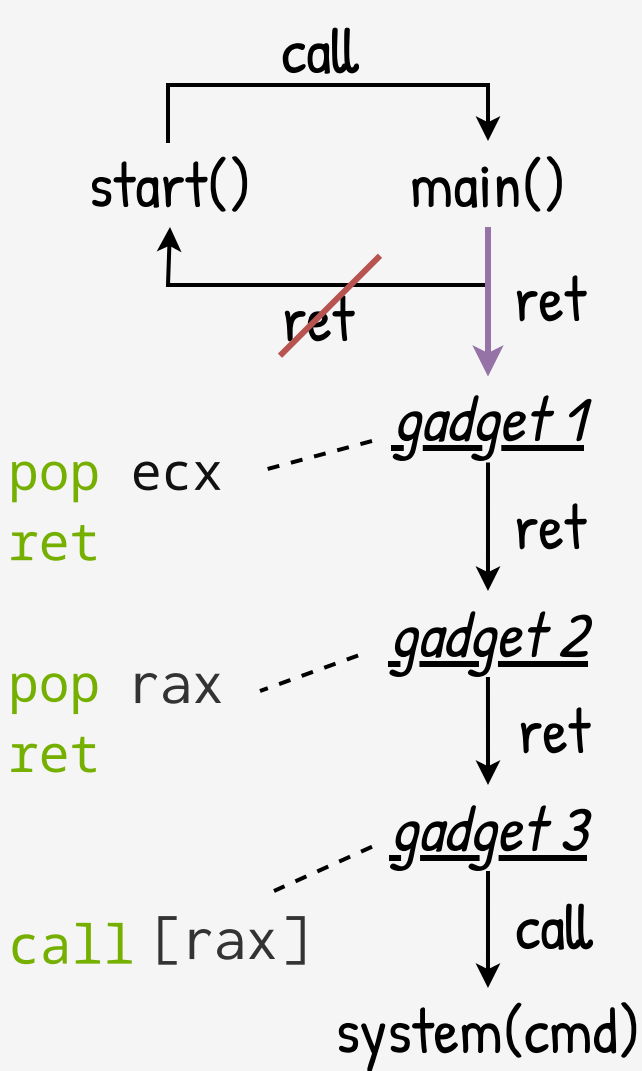
`call [rax]`

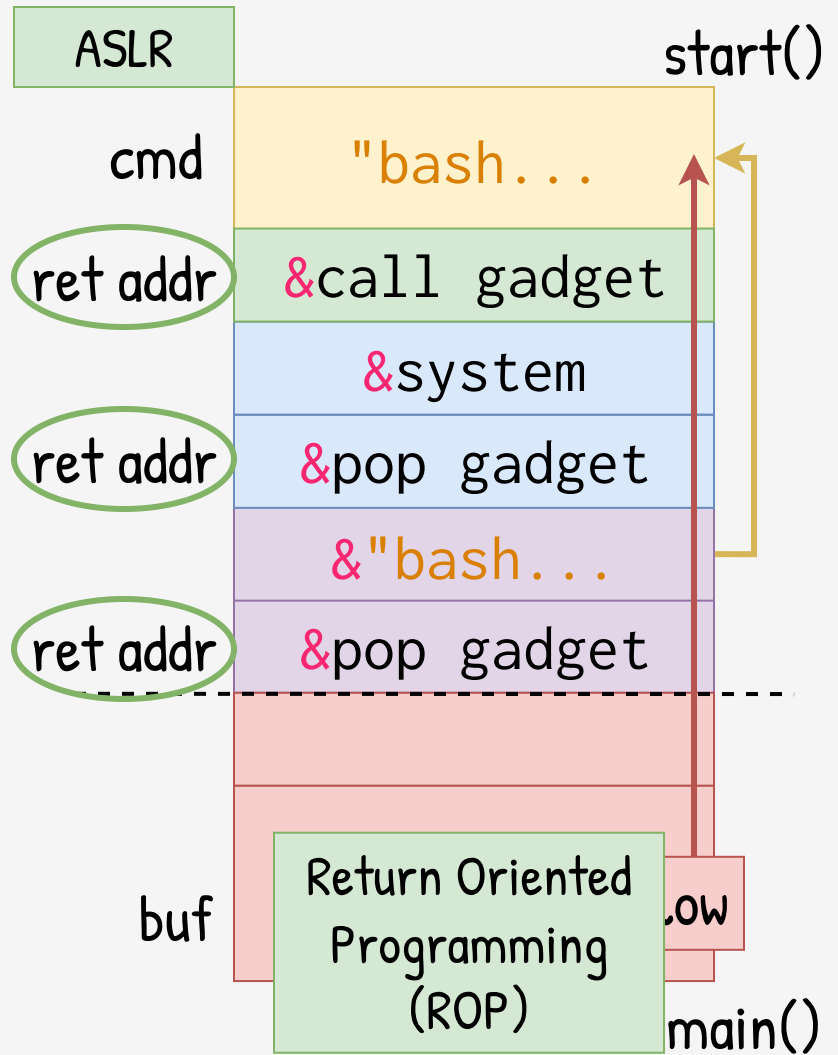
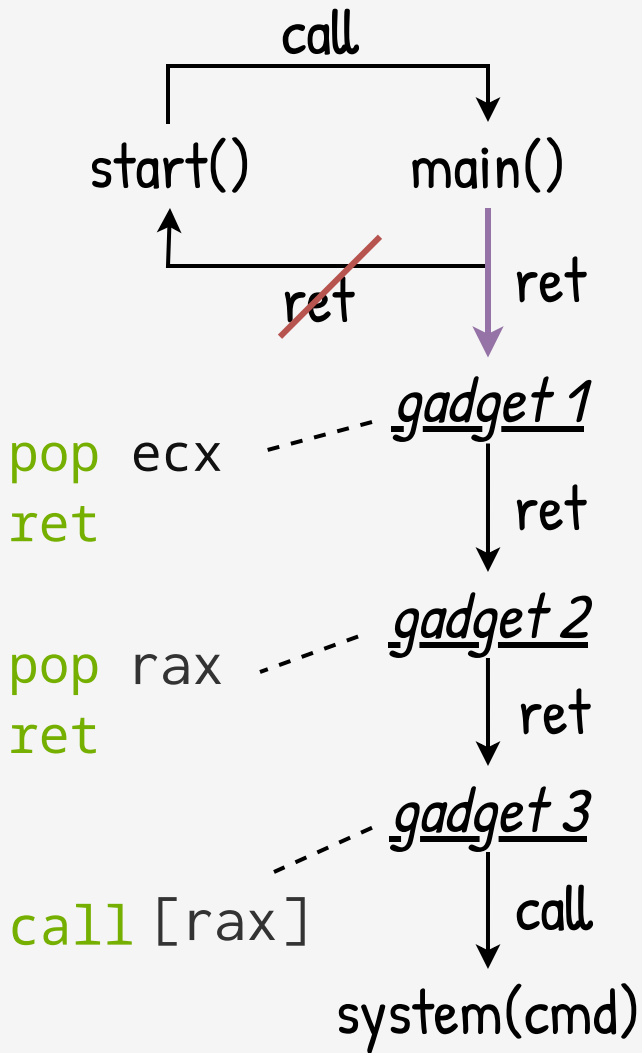


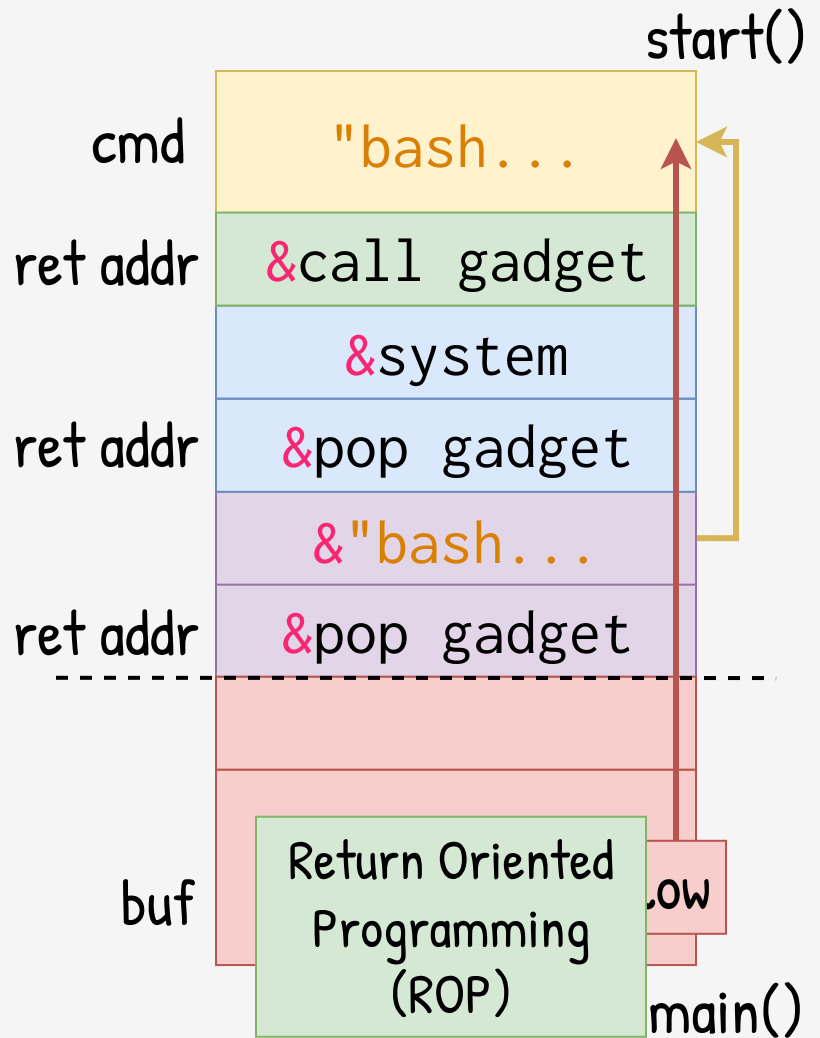
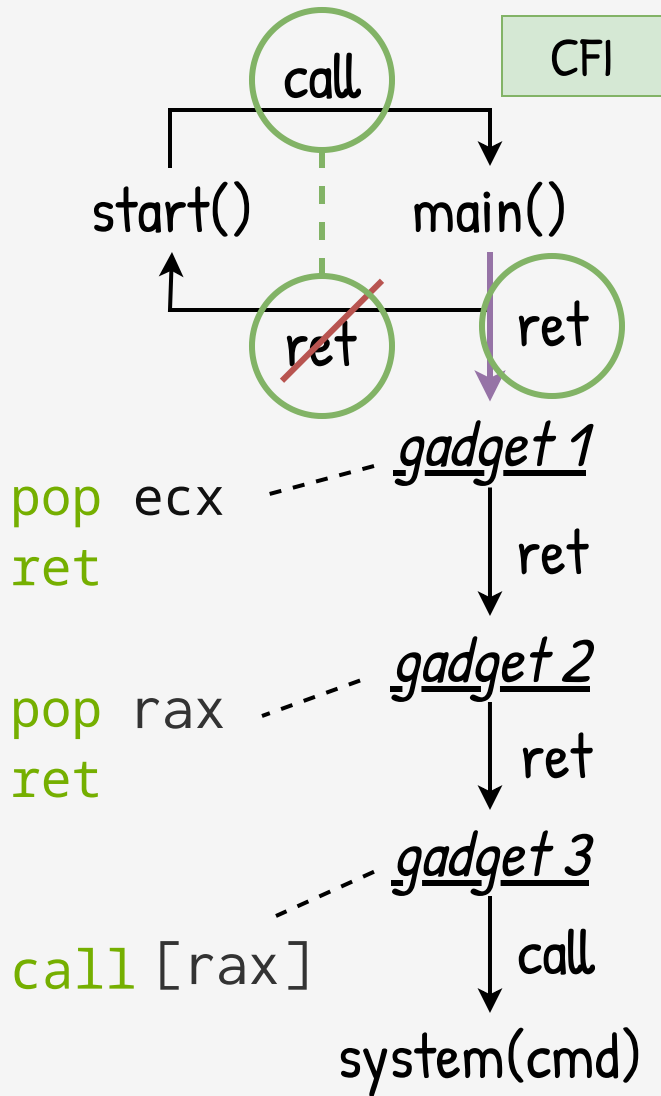


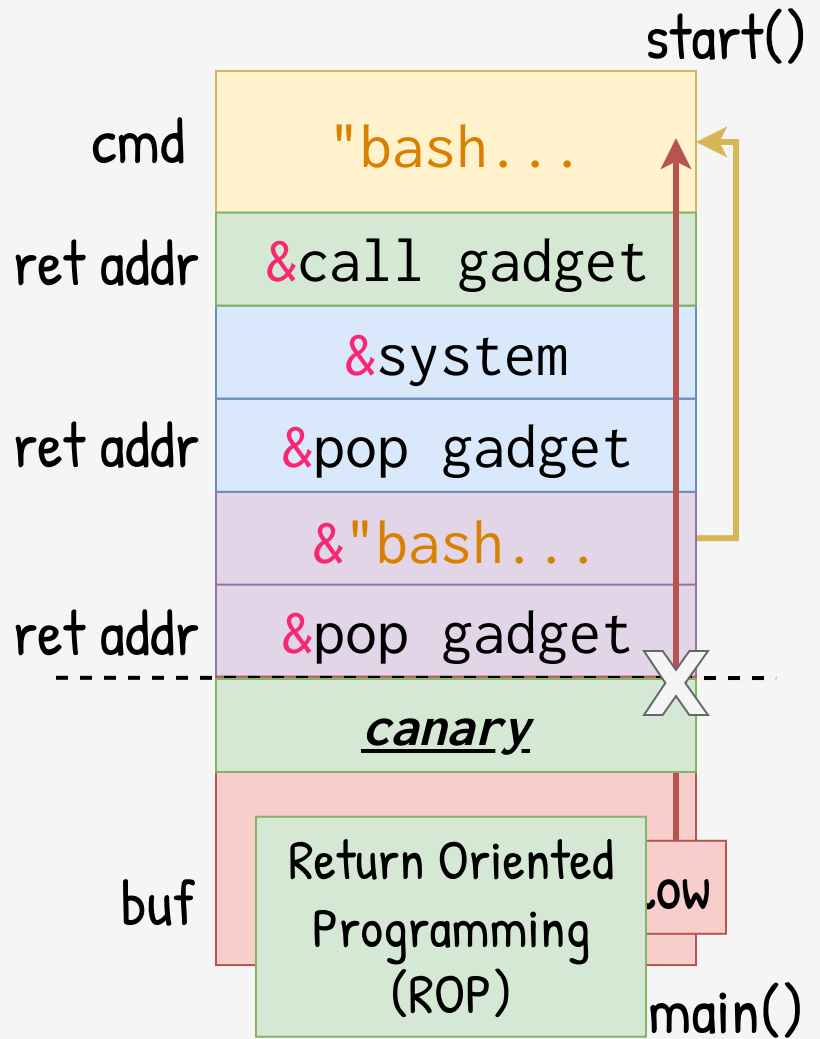
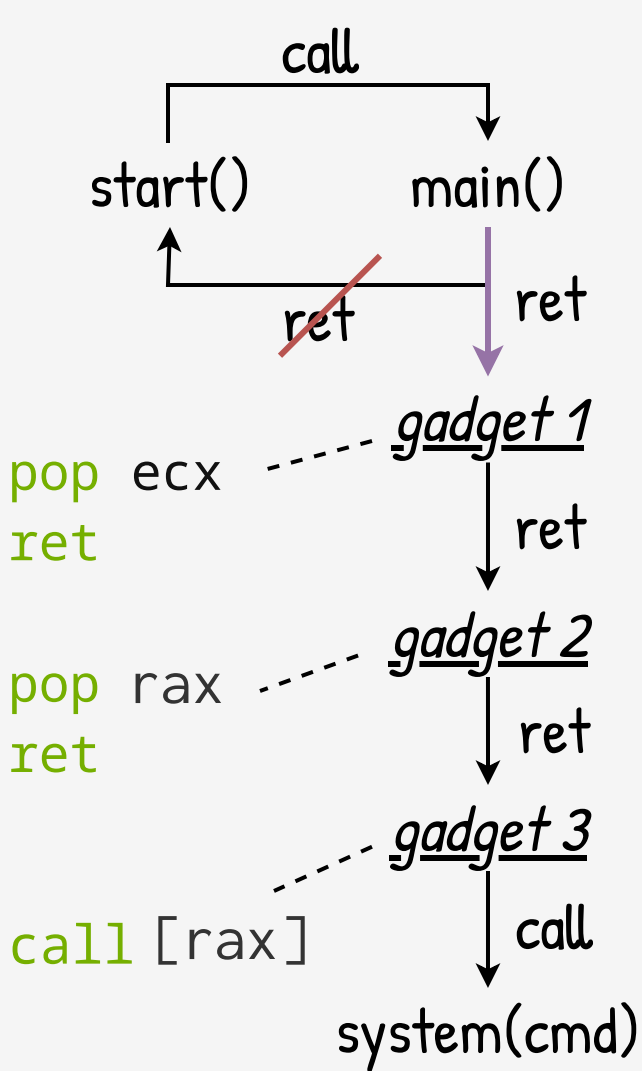












Takeaways

